Budgetly: Sprint 3 Static Analysis Summary

Author: Tyler Petersen | CIS 675 / CSCI 475 | Scans run: October 19, 2026

1. Tools Used

- **Programming languages:** JavaScript (React web app and Node.js Cloud Functions), CSS, YAML (GitHub Actions workflows).
- **SonarQube:** SonarQube Cloud (sonarcloud.io), Team plan trial, "Sonar way" quality gate, automatic analysis of the `main` branch.
- **Trivy scan type:** filesystem scan for dependency vulnerabilities (`trivy fs --scanners vuln`).
- **Where the scans ran:** Trivy was run locally on my computer. SonarQube Cloud analysis ran in SonarQube Cloud (automatic analysis, not local and not in our CI).

2. Required Metrics

SonarQube (Overall Code)

Project	Bugs	Vulnerabilities	Code Smells	Security Hotspots	Quality Gate
budgetly_backend_nodejs (3.3k lines)	14	1	3	0	Pass
budgetly_web_customer (4.3k lines)	8	4	4	0	Pass
Total	**22**	**5**	**7**	**0**	**Pass (both)**

Trivy (vulnerabilities by severity)

Target	CRITICAL	HIGH	MEDIUM	LOW
budgetly_backend_nodejs/functions/package-lock.json	0	0	1	0
budgetly_web_customer/package-lock.json	0	2	0	1
Total	**0**	**2**	**1**	**1**

Trivy findings: uuid 9.0.1 (MEDIUM, backend); @grpc/grpc-js 1.9.16 (HIGH and LOW, web); source-map-js 1.2.1 (HIGH, web). All have fixed versions available.

3. Scope

- **Scanned:** both code repositories, `budgetly_backend_nodejs` (Cloud Functions, Firestore and Storage rules, tests) and `budgetly_web_customer` (React web app). Trivy scanned all five

project repositories; the SonarQube analysis ran on copies (forks) of the two code repositories made on October 19, 2026, containing the current `main` branch including all Sprint 3 work.

- **Excluded / not applicable:** `budgetly_contracts`, `budgetly_assets` and `budgetly_web_dash` contain only documentation, reports and a README, with no source code or dependency manifests, so they produced no findings. Trivy ignores development-only dependencies by default. Test coverage was not configured in SonarQube.

4. Trend

- **SonarQube:** Baseline sprint — no prior comparison (no earlier SonarQube report was recorded).
- **Trivy:**

	CRITICAL	HIGH	MEDIUM	LOW	Total
Sprint 2 (scan of October 5, 2026)	0	1	1	1	3
Sprint 3 (scan of October 19, 2026)	0	2	1	1	4

The increase is one new HIGH finding (source-map-js 1.2.1) in the web app's dependencies.

5. Reflection

The most problematic area is reliability: SonarQube reports 22 bugs in total (14 in the backend, 8 in the web app, rated C and D), followed by outdated dependencies, including the two HIGH findings in @grpc/grpc-js and source-map-js. Next sprint we plan to go through the SonarQube bug list by severity and fix the highest-severity ones first, update the vulnerable dependencies (all have fixed versions), and rerun both tools to confirm the counts go down.

This static analysis was generated using automated tools during this sprint.